

An Innovative Risk Score Based Corporate Access Control Management System

Busra OZDENIZCI KOSE

Dept. of Management Information Systems
Gebze Technical University
Kocaeli, Türkiye
busraozdenizci@gtu.edu.tr

Vedat COSKUN

Dept. of Software Engineering
Istanbul Atlas University
Istanbul, Türkiye
vedat.coskun@atlas.edu.tr

Arslan COSKUN

TURCOM Technology
Istanbul, Türkiye
carslan@turcom.com.tr

Abstract—Rapid advances in information technology have increased organizations' dependence on computer systems to store and process data. However, this has also increased security vulnerabilities, especially with the increasing complexity of infrastructure systems that include centralized, cloud-based, and other platforms. The current situation is complicated by many factors, including varying authentication needs across departments, challenges managing access of external staff, and disparate log records created by subsystems in organizations. In this context, today organizations need effective authentication and access control strategies in managing and accessing their corporate resources and assets. This study introduces an innovative approach called Risk Score based Corporate Access Control Management (RS-CACM) system. RS-CACM provides a strengthened and efficient access control mechanism by issuing access requests to computer systems, regardless of whether they are hosted on cloud platforms or on an organization's physical infrastructure. In this study, the operating features, requirements, and functionalities of the RS-CACM system are explained.

Keywords—access control, authentication, MFA, risk score, security, privacy.

I. INTRODUCTION

In recent years, rapid progress in information technology has led to the widespread use of computer systems for information storage and processing. This increased the capabilities and efficiency of these systems. But it has also introduced increased security risks and magnified the potential consequences of breaches. Now more than ever, organizations are becoming increasingly dependent on the information they manage. At this point, accessing corporate resources and assets through secure access control mechanisms and policies is a very important requirement.

Access control service is a crucial element of organizational security and operations, as it oversees all accesses to a system and its resources, guaranteeing only authorized entries [1-3]. The term access control refers to the selective restriction of access to a place or other resource, ensuring that only authorized individuals can access specific resources at appropriate times and under specific conditions [4-6]. This strategic process goes beyond just granting entry to physical locations; it also encompasses digital resources, including databases, files on the cloud and network access. Almost all management systems incorporate access control service to define rules as policies using a specific specification language. These rules are then implemented by the access control mechanism responsible for the service. Through the designated interface, security administrators can outline the access control guidelines to regulate access to the resources in question [1, 3].

Currently, organizations are facing diverse challenges in managing their access control policies, especially with the emergence of multifaceted infrastructure systems. These systems, which may include centralized, cloud-based, and other platforms, pose unique security and operational concerns. One pressing issue is users with administrative privileges accessing these systems through VPN (Virtual Private Network), granting them widespread access across all platforms. This issue becomes even more complex with the existence of different support staff across various departments, each requiring separate authentication processes. In multi-user environments, ensuring access security becomes increasingly challenging, especially when considering personnel changes, or role transitions. Furthermore, managing access for support staff from outside the company adds another layer of complexity. Ensuring safe and appropriate access in such complex environments requires rigorous planning and robust control mechanisms.

In this complex environment, various issues and problems need to be resolved. As highlighted in Figure 1, the inadequacy of using mostly one-factor authentication method results in security vulnerabilities, as well as managing user accounts that need to access multiple subsystems becomes increasingly complex. There's also the challenge of handling accounts of employees who either leave the company or change positions. Another complication is that these subsystems produce independent log records, making consolidated oversight difficult. Managing external support teams, especially in terms of limited authority and time-bound access, presents its own set of challenges. In suspicious circumstances, there's a dependency on system administrator approval, which can delay critical actions. In addition, there's a continuous demand for secure remote access to company IT resources, but only for those with the necessary permissions. Identifying and taking precautions against malicious users is crucial. Lastly, the management of unused accounts is necessary to prevent potential security breaches. These multifaceted challenges underscore the need for robust access control and management strategies.

This study presents an innovative Risk Score based Corporate Access Control Management (RS-CACM) system that enables the management of access requests to computer systems located in an organization's cloud platforms or its own physical infrastructure. Accordingly, the rest of the paper is organized as follows: Section II briefly describes the authentication and MFA concepts which are the fundamentals of proposed model. Section III presents the overall system context and functionalities in detail and Section IV concludes with the implications of proposed system.

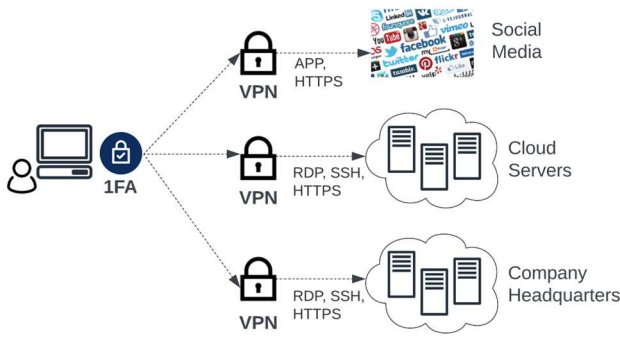


Fig. 1. An existing access control solution in organizations

II. BACKGROUND

Authentication is a foundational step for access control. Authentication can be defined as “the provision of assurance in the claimed identity of an entity” [7]. Authentication, whether offline or online, remains a critical precaution against unauthorized access to the device or any other sensitive application [8-11]. Before access control service can determine what a user can access, authentication must verify the user's identity. Once authenticated, access control service then provides the appropriate level of access based on predefined permissions.

In order to authenticate an entity, ISO/IEC 29115 Entity Authentication Assurance Framework [7] standard defines four levels of assurance (LoA). Each LoA shows the degree of confidence in the processes that are including an authentication [7, 12, 13]: LoA1 means little or no confidence in the asserted digital identity; LoA2 shows some confidence in the asserted digital identity and generally is used for self-service applications; LoA3 provides high confidence in the asserted digital identity and mainly is used to access protected data; and LoA4 shows very high confidence in the asserted digital identity and allows to access highly protected data.

Generally, there are three categories of credentials or factors for user authentication process: Something you know (e.g., a username with password or PIN data), Something you have (e.g., SIM cards with mobile number, smartcards or access cards, or a mobile device), Something you are (e.g., a fingerprint, face recognition or other biometric data). One-factor authentication (1FA) based solutions are user-friendly, but over time these solutions fell short for value-added, sensitive applications. They are not reliable solutions to provide adequate protection due to several security threats [14, 15]. To enable sensitive services, at least making use of two factors have become a necessity. In this regard, two-factor authentication (2FA) mechanisms using both knowledge factors -like a username and password - and ownership factors -like a smartcard, smartphone application, or OTP- are widely used by service providers particularly in the banking and financial sectors [12, 16, 17].

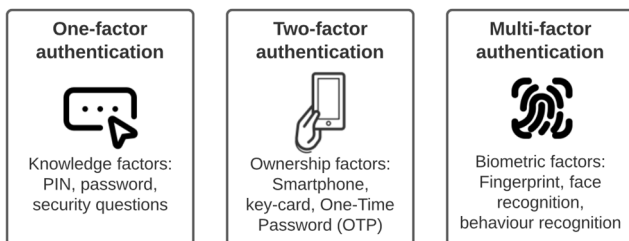


Fig. 2. Authentication Methods [11]

Even when second knowledge factor is used, either LoA2 or LoA3, but not LoA4 can be satisfied [7, 18]. In cases where a highest level of assurance if required, multi-factor (meaning three-factor indeed) authentication (MFA) systems (Fig. 1) have been proposed in recently to provide an improved level of security and strong authentication for highly sensitive applications such as e-government, e-payment, e-health platforms. MFA systems mainly benefit from biometrics which can be the automated recognition of individuals based on their behavioral and biological characteristics [17, 18].

III. SYSTEM CONTEXT

This section presents the essential components and functionalities of the proposed RS-CACM system (as shown in Figure 3) which are user authentication management, session logs and access management, remote access management without using VPN, user risks management and system modules.

A. User Authentication Management

In the RS-CACM system to be developed, an architecture is adopted in which it is defined within what authority each user can access each resource in the IT infrastructure. This architecture includes the subsystems of the entire IT infrastructure and must be able to perform fast and dynamic action for each user. 2FA, 3FA, MFA methods can be used as access control methods as necessary (Figure 3). In this way, an appropriate balance will be created between security and functionality.

At the same time, Self-Sovereign ID (SSI) and Blockchain technologies can also be integrated in user authentication processes. A Blockchain based SSI platform will be established in which the user can store the information that he/she wants to have and does not want to disclose to the organization. The user information will be in a personal wallet, the DID (Decentralized Identifier) information to be used for verification will be in the blockchain network, and the SSI authentication module will be on the RS-CACM server. When the user logs into the system, SSI will use a DID key during authentication and the RS-CACM will perform the necessary verification with this DID information and authenticate the user.

Accounts will be defined on the RS-CACM system for each company manager and end users who will access the RS-CACM server to be developed. To ensure this, RS-CACM is based on the RADIUS authentication system in its own infrastructure, but MS AD (Microsoft Active Directory), LDAP (Lightweight Directory Access Protocol) REST API (Representational State Transfer Application Programming Interface), SOAP API (Simple Object Access Protocol Application Programming Interface) authentication systems will also be supported as third-party authenticator systems.

B. Session Logs and Access Control Management

Within the scope of the RS-CACM system, users' activities after receiving permission to access the system will be monitored, live suspicious transactions will be detected, and preventive action will be taken quickly against them. For this purpose, *unauthorized action prevention (UAP) algorithm and mechanism* will be developed. This algorithm decides whether each transaction is safe or not by looking at each user's profile, the transactions they are authorized for, their transactions to date and other information.

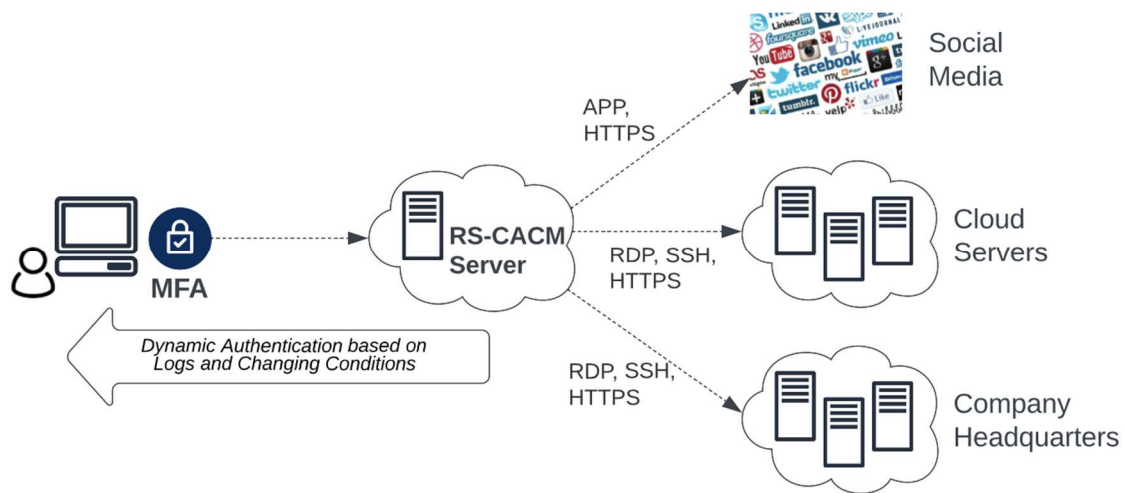


Fig. 3. Context of Proposed Model

Some of the critical parameters to be used in the UAP algorithm are as follows: day and time the user accessed, IP address or geographical location accessed, connected device type and operating system, connected web browser and version, number of incorrect entries within a certain period, time differences between login attempts, pattern types used by the user during login, historical access frequency, number of successful logins. In the light of these parameters and collected data, UAP algorithm calculates an active Risk Score for each user and make a decision (such as authorize access of the user, direct the user for additional authentication, deactivate/suspend the user account, or request approval from the system administrator) based on this risk score (Figure 4).

The transactions made by every user who accesses the corporate systems are recorded. By using these session records, it is ensured that the RS-CACM system operates effectively and intervenes when necessary. A weight coefficient expressing the importance level of each parameter in question is created. When the user tries to log in at a certain time, it is taken into the system to be evaluated with the determined weight coefficients, and the collected information is multiplied by the relevant coefficients to calculate a risk score in the range of 0-100. In any case, all results will be reported to the system administrator. An example risk score evaluation might look like this:

- **Low Risk:** For user authentication, using only username and password is sufficient; or user can continue with the last used authentication process like 1FA or 2FA.
- **Medium Risk:** For authentication, a higher-level authentication process, MFA should be initiated. The user is expected to log in to the system using this method.
- **High Risk:** For authentication, in addition to MFA, information such as e-mail messages, phone calls or biometric data must be used; or request approval from the administrator must be initiated; or the access can be blocked.

Periodic evaluation of risk score effectiveness is an important feature of the proposed system. Risk score

calculations and other activities performed on the system will be monitored periodically, and the parameters and coefficients used in calculating the risk score will be updated when necessary. Thus, it is aimed to maximize system security by developing a dynamic and intelligent risk score calculation method. Some scenarios that may occur during the users' access to corporate resources are defined as follows:

Scenario 1 - Unknown User: The user enters any username that is not registered in the system and tries to login with his/her password. In this scenario, since the username with which the user is trying to login is not registered in the system, either the username has been entered incorrectly or a malicious user is trying to login without authorization (possibly a brute force attack). In such a case, the following steps will be followed:

- If the person trying to access makes this attempt a certain number of times (e.g., 3 times) within a certain period (e.g., 1 minute), the login request will not be sent to this person for a certain period (e.g., 5 minutes).
- Afterwards, a query, such as a captcha, will be presented and if successful, the user will be directed back to the login screen.
- To increase security, waiting periods will be imposed after unsuccessful queries.

Scenario 2 - Known User, Incorrect Password: If the person trying to login has entered a valid username, then it is more likely that he/she is a valid user.

- If the person logs in incorrectly more than a certain number of times (e.g., 3 times), the steps under the "Unknown User" heading will be implemented. At this stage, the login records of this username will be examined and whether there have been any previous incorrect logins and password change transactions will be evaluated as well.
- On the other hand, in parallel with this, warning messages regarding this process will be sent to the e-mail address of this username and to the system administrator.

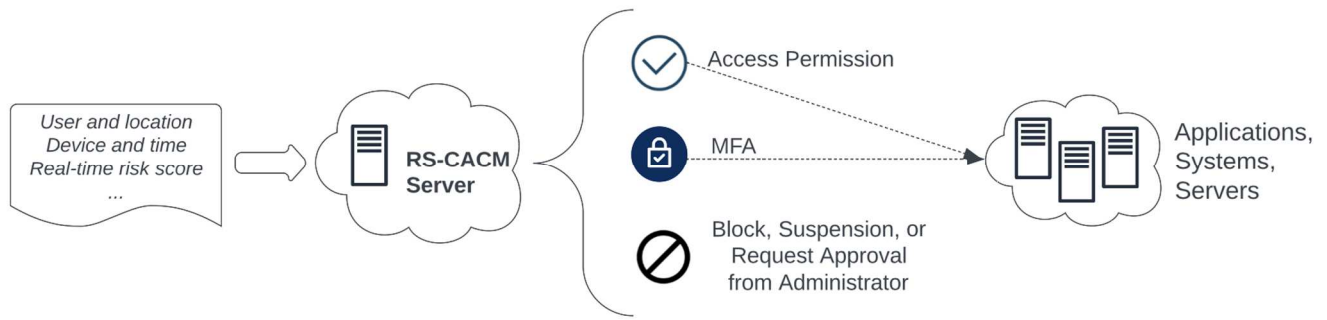


Fig. 4. How System Works

Scenario 3 - Known User, Correct Password: The RS-CACM server has a critical function as it keeps the accounts of all system and network devices. For this reason, it becomes very important to ensure access security of the RS-CACM server. An authentication system of at least 2FA level (e.g., MFA) will be preferred when accessing the RS-CACM server (Figure 4). At a higher level of security, additional authentication methods (e.g., a biometric data or a different authentication element like mobile phone) will be used. In all cases, when 2FA authentication is used, the person who will gain access will enter a username-password combination. If this information is verified, a second verification will be made through something the user has such as SMS, PIN, QR code.

As a result of the risk score calculation, if the users currently logged in verification level is not deemed sufficient during the authentication process being carried out at that moment (such as 2FA), then a higher-level authentication method (such as MFA) will be activated dynamically. If the user authenticates at this level, they will be allowed to continue; otherwise, the user account will be temporarily or permanently suspended, and a warning message will be sent to the system administrator.

C. Remote Access Management without VPN

The RS-CACM server, which will be accessed via the HTTPS supported web interface, brings resources to the user screen by providing access to the computer and network systems defined and registered on it. Since the RS-CACM server will be located in the secure zone (DMZ) defined and protected by the firewall, the disadvantages of VPN access will be eliminated. Users will have easy, secure access to the network resources they need, wherever they are.

D. User-related Risks Management

In a situation where the number of users is high and the IT infrastructure to be accessed includes many systems, effective management of user accounts can become a significant problem. In the proposed RS-CACM system, authorization can be provided directly to devices when defining users, or authorization can be provided by grouping devices in certain authorization groups and including users in these groups. The RS-CACM system will keep an inventory of unused authorizations and resources by constantly monitoring the activities of user accounts, and depending on the preference, these will be automatically removed from the authorization pool or reported to the system administrator.

E. System Development Modules

The RS-CACM system will be developed in three essential modules: Resource Management, Access Management and Decision Management.

The Resource Management module will manage all network resources to be accessed. This module must be able to access network and system infrastructures using RDP (Remote Desktop Protocol), SSH (Secure Shell) or other technologies. At this stage, the user interface that will allow access authorization to network devices will be developed.

The Access Management module will manage all users and their access methods with the proposed UAP algorithm supported by machine learning. This module will provide MS AD, LDAP, and RADIUS integrations as well as necessary integrations with other technologies on a priority basis such as Blockchain, SSI, SSO (Single Sign-On).

The Decision Management module will provide the decision mechanism. Security risks that may arise from users will be prevented by analyzing historical login data, which makes the proposed system innovative. By analyzing data such as past system records, current access information, information about sessions, log records from networks and computers, users' previous behaviors and temporal evaluations of access to servers and systems, it is planned to run predetermined scenarios for unusual situations. As a result of this analysis, actions such as logging the user into the system, dynamically configuring the user's authentication systems, or suspending the user account, can be taken.

IV. CONCLUSION

This study presents an innovative and dynamic risk score based corporate access control management system. The system functionalities including the promising algorithm essentials are all described. The further work will include the development and testing studies of the proposed RS-CACM system. The proposed system has following implications and results for the corporates who are seeking for an promising access control management system:

- Security issues arising from inadequate use of 1FA and/or 2FA can be managed dynamically with the proposed risk score-based approach. It is especially beneficial to identify situations where 2FA may be insufficient and to use more secure MFA applications.
- The challenge of managing user accounts accessing more than one subsystem is resolved. A unified identity and access management system can simplify the management of accounts across multiple systems.
- Quick management of the accounts of users who leave their jobs or change positions is ensured. Dynamic monitoring of user accounts and regular audits ensure that accounts are disabled, or necessary/unnecessary user access permissions are updated.

- A centralized logging and monitoring system is provided instead of subsystems that produce independent log records; this makes it easier to monitor and analyze activities in all systems.
- Access processes of external support teams with limited authority in a time-bound become manageable. Temporary access tokens or timed permissions can be used to provide temporary access for such cases.
- In suspicious cases, the need for system administrator approval is accelerated and made dynamic. An automatic alert mechanism is provided to notify system administrators to take immediate action (such as block or suspend) on suspicious activity.
- Only authorized users can request secure remote access to the company's IT resources, without the need for VPN.
- Detecting malicious users and taking precautions becomes dynamic with machine learning methods. Monitoring and anomaly detection tools can be used to detect unusual behavior and appropriate measures can be taken against malicious users.
- It becomes easier to identify and close unused accounts. All user accounts can be regularly audited with a risk score-based approach, and accounts that have not been used for a period can be automatically disabled.

REFERENCES

- [1] Sandhu, R. S., & Samarati, P. (1994). Access control: principle and practice. *IEEE communications magazine*, 32(9), 40-48.
- [2] Sandhu, R. S., & Samarati, P. (1997). Authentication, Access Controls, and Intrusion Detection. *The Computer Science and Engineering Handbook*, 1, 929-1.
- [3] Samarati, P., & de Vimercati, S. C. (2000). Access control: Policies, models, and mechanisms. In *International school on foundations of security analysis and design* (pp. 137-196). Berlin, Heidelberg: Springer Berlin Heidelberg.
- [4] De Capitani di Vimercati, S., Paraboschi, S., & Samarati, P. (2003). Access control: principles and solutions. *Software: Practice and Experience*, 33(5), 397-421.
- [5] Benantar, M. (2005). Access control systems: security, identity management and trust models. Springer Science & Business Media.
- [6] Ballad, B., Ballad, T., & Banks, E. (2010). Access control, authentication, and public key infrastructure. Jones & Bartlett Publishers.
- [7] ISO/IEC 29115 (2013). Information technology-Security techniques-Entity authentication assurance framework.
- [8] Boyd, C.; Mathuria, A. *Protocols for Authentication and Key Establishment*; Springer: Berlin, Germany, 2013.
- [9] Mohsin, J.; Han, L.; Hammoudeh, M.; Hegarty, R. Two Factor vs. Multi-factor, an Authentication Battle in Mobile Cloud Computing Environments. In *Proceedings of the International Conference on Future Networks and Distributed Systems*, Cambridge, UK, 19-20 July 2017; ACM: New York, NY, USA, 2017; p. 39.
- [10] Pathan, A.S.K. *Security of Self-Organizing Networks: MANET, WSN, WMN, VANET*; CRC Press: Boca Raton, FL, USA, 2016.
- [11] Ometov, A., Bezzateev, S., Mäkitalo, N., Andreev, S., Mikkonen, T., & Koucheryavy, Y. (2018). Multi-factor authentication: A survey. *Cryptography*, 2(1), 1.
- [12] Ozdenizci Kose, B., Buk, O., Mantar, H. A., & Coskun, V. (2020, October). TrustedID: An Identity Management System based on OpenID Connect Protocol. In *2020 4th International Symposium on Multidisciplinary Studies and Innovative Technologies (ISMSIT)* (pp. 1-6). IEEE.
- [13] Ozdenizci Kose, B., Buk, O., Mantar, H. A., Coskun, V., & Erdemir, U. (2021). Protecting Mobile Service User Identity by Adding Additional Security Layer. *Avrupa Bilim ve Teknoloji Dergisi*, (23), 22-30.
- [14] Kim, J.J.; Hong, S.P. A method of risk assessment for multi-factor authentication. *J. Inf. Process. Syst.* 2011, 7, 187-198.
- [15] Gunson, N.; Marshall, D.; Morton, H.; Jack, M. User perceptions of security and usability of single-factor and two-factor authentication in automated telephone banking. *Comput. Secur.* 2011, 30, 208-220.
- [16] Sun, J.; Zhang, R.; Zhang, J.; Zhang, Y. Touchin: Sightless two-factor authentication on multi-touch mobile devices. In *Proceedings of the Conference on Communications and Network Security (CNS)*, San Francisco, CA, USA, 29-31 October 2014; pp. 436-444.
- [17] Aloul, F., Zahidi, S., & El-Hajj, W. (2009). Multi factor authentication using mobile phones. *International Journal of Mathematics and Computer Science*, 4(2), 65-80.
- [18] Abhishek, K., Roshan, S., Kumar, P., & Ranjan, R. (2013). A comprehensive study on multifactor authentication schemes. In *Advances in Computing and Information Technology: Proceedings of the Second International Conference on Advances in Computing and Information Technology (ACITY)* July 13-15, 2012, Chennai, India-Volume 2 (pp. 561-568). Springer Berlin Heidelberg.